Sri Lanka Institute of Information Technology

Faculty of Computing, Department of Computer Systems Engineering

IE3122: Network Security

Week 12 Tutorial Worksheet 2: Integrity, Signatures, and PKI

Field	Detail
Based on	Week 12 Deck B, Integrity, Signatures and PKI lecture (hash functions, MACs and HMAC, digital signatures, certificates, PKI, TLS handshake, Cisco PKI overview)
Learning Outcomes	LO3 (analyse security requirements), LO4 (evaluate and compare security technologies), LO5 (configure security technologies)
Format	15 structured questions, no MCQs. Answer in your own words. The last question asks you to reason about real router configuration.
How to use this	Answer every question in the space provided. Together, your answers form a set of study notes for this topic. Use them directly when revising for the mid-semester test and final exam.

These questions are drawn directly from this week's Integrity, Signatures and PKI lecture. Many ask you to compare or recommend, which is deliberate: the three tools of hash, MAC, and signature are easy to confuse, and the exam rewards knowing exactly what each one guarantees. Write full answers, not one-line definitions.

Hash Functions

Q1. Explain the difference between second-preimage resistance and collision resistance, and give a short example scenario in which an attacker would need to defeat each one. *[LO3]*

Q2. A website stores its users' passwords as unsalted SHA-256 digests. Describe two attacks that this design is vulnerable to, and recommend a better design, naming the two specific changes you would make. *[LO3, LO4]*

Q3. A software vendor publishes a download link and the file's SHA-256 digest on the same web page. Evaluate how much assurance this gives a user, and describe what would improve it. *[LO4]*

MACs and HMAC

Q4. Explain why an attacker can defeat a plain hash used to protect a message in transit, but cannot defeat an HMAC. Use a short example. *[LO3]*

Q5. Alice and Bob protect their messages with an HMAC using a shared key. Explain why this cannot provide non-repudiation, and what Alice could claim if she later wanted to deny sending a message. *[LO4]*

Digital Signatures

Q6. Describe the steps a sender follows to sign a message and the steps a receiver follows to verify it. Explain why the sender signs the digest rather than the whole message, and state what a successful verification does and does not prove. *[LO3, LO4]*

Q7. Compare a hash, a MAC, and a digital signature, and recommend which one to use for each of the following, justifying each choice: (a) checking a downloaded file against a published digest, (b) protecting the integrity of IPsec packets between two routers, (c) proving that a software update came from the vendor. *[LO3, LO4]*

Digital Certificates

Q8. Explain how a man in the middle can defeat both encryption and digital signatures when the receiver has no way to check whose public key it holds, and explain how a certificate removes this weakness. *[LO3]*

Q9. List at least five checks a browser performs when verifying a server's certificate, and for each, say what attack or error it protects against. *[LO3, LO4]*

Q10. Compare a domain validated (DV) certificate with a self-signed certificate. Recommend which is appropriate for (a) a public online shop and (b) an internal lab device, and justify each choice. *[LO4]*

PKI

Q11. Explain why a PKI uses a root CA and intermediate CAs, rather than having the root sign every certificate directly. What would be the consequence of the root's private key being compromised, compared with an intermediate's? *[LO4]*

Q12. Compare CRL and OCSP as methods of checking revocation, and explain why revocation checking is often described as the weak point of PKI in practice. *[LO4]*

Q13. Describe what happened in the 2011 DigiNotar incident, explain what it shows about the PKI trust model, and name one defence that was introduced as a result. *[LO4]*

Putting It Together

Q14. In a TLS 1.3 handshake, identify which cryptographic primitive (key agreement, certificate, digital signature, MAC, or symmetric encryption) is responsible for each of the following: agreeing the session key, proving the server's identity, proving the server holds the certificate's private key, confirming the handshake was not altered, and protecting the application data. *[LO3]*

Q15. Router R1 needs a certificate so it can authenticate IPsec peers. Put these steps in the correct order and explain each one: create the trustpoint, generate the RSA key pair, enrol with the CA, authenticate the CA. Explain why authentication must come before enrolment, and why revocation-check none should only be used in a lab. *[LO5]*

Turning This Into Exam Revision

Once you've answered every question, you have the beginnings of a proper study-notes set for this topic. To make it exam-ready:

1. Reread each answer and check it would make sense to you in three months, without the lecture slides open.
2. The comparison and recommendation questions (hash, MAC and signature, and DV versus self-signed certificates) ask you to choose between options for a specific scenario. Practise naming what each primitive guarantees and what it does not, since exam questions often hinge on that difference.
3. The final question mirrors real router configuration. If you can answer it without the slides, the configuration steps will go much faster when you meet them in practice.
4. Keep this worksheet with your notes for the mid-semester test (MCQ, LO1 and LO2) and final exam (MCQ + structured essay, LO1 through LO5).